

PrimeHealth Clinic & Diagnostics

Information Security Policy

Document Version History

Date	Version	Updated By	Details of Change	Approved By
21/10/2024	1.0	Whole Team	Basic Draft of document	Executive Team
22/10/2024	1.0	Whole Team	Draft in progress	Executive Team
23/10/2024	1.0	Whole Team	Document Complete	Executive Team
24/10/2024	1.0	Whole Team Aaron (CEO)	Approval	Executive Team

Table of Content

Table of Content	1
1. Purpose	2
2. Scope.....	3
3. Senior Management Commitment.....	3
4. Information Security Objectives	3
5. Security Framework and Controls	4
6. Incident Management.....	4
7. Legal and Regulatory Compliance	5
8. Training and Awareness.....	5
9. Incident Reporting and Breach Management.....	5
10. Continuous Improvement and Review	6
11.Supporting reference and evidence documents	6

1. Purpose

The purpose of this Information Security Risk Treatment Policy is to ensure a systematic approach in handling information security risks for PrimeHealth Clinic & Diagnostics. This involves:

- Determining the most suitable risk treatment methods based on the insights gathered from the risk assessment, ensuring that the chosen options effectively minimize the risks to an acceptable level.
- Identifying and selecting appropriate controls aligned with the risk treatment strategies, ensuring these controls are designed to mitigate the identified risks efficiently.
- Verifying that the selected controls in point b) align with the controls specified in Annex A of ISO 27001:2022, ensuring no critical control is omitted during the process.
- Compiling a Statement of Applicability (SoA), which includes all identified controls from points b) and c), along with explanations for their inclusion. The SoA will also provide a justification for any controls that have been excluded, regardless of their current implementation status.
- Creating a detailed Information Security Risk Treatment Plan, outlining the chosen risk treatment strategies, the associated controls, timelines for implementation, and designated responsibilities.
- Securing the approval of risk owners for the proposed Information Security Risk Treatment Plan, ensuring that they agree on both the plan and the residual risks that remain after mitigation efforts.

This Information Security Policy outlines PrimeHealth Clinic & Diagnostics' commitment to preserving the confidentiality, integrity, and availability of all its digital information assets in compliance with ISO 27001:2022 standards. This policy ensures that senior management actively supports and drives information security initiatives and commits to continuous improvement of the Information Security Management System (ISMS).

2. Scope

This policy applies to all PrimeHealth employees, contractors, third-party vendors, and any external parties who have access to the organization's information systems. The scope covers:

- All locations: PrimeHealth's clinical and diagnostic center and Head office
- All information assets: Include digital data such as patient records, financial data, telehealth records, diagnostic data, and intellectual property.
- All business functions: Encompassing administration, patient care, diagnostics, finance, and HR.

3. Senior Management Commitment

PrimeHealth's senior management fully commits to safeguarding the organization's information assets through the effective implementation and continuous improvement of the Information Security Management System (ISMS). This commitment includes:

- Ensuring Compliance: Aligning with legal, regulatory, and contractual requirements (e.g., Privacy Act 1988, GDPR, HIPAA).
- Providing Resources: Allocating necessary resources (human, financial, and technical) to maintain and improve the ISMS.
- Setting Objectives: Defining, monitoring, and reviewing security objectives that align with organizational goals.
- Continuous Improvement: Actively supporting a culture of continuous improvement, risk management, and compliance.

4. Information Security Objectives

PrimeHealth aims to achieve the following key security objectives:

1. Confidentiality: Ensure that sensitive information (e.g., patient data, financial records) is accessible only by authorized individuals.
2. Integrity: Protect information from unauthorized modifications to maintain its accuracy and reliability.
3. Availability: Ensure that critical systems and data are available when needed to support patient care, diagnostics, and operations.
4. Compliance: Meet all legal, regulatory, and contractual obligations to avoid financial penalties and maintain trust with stakeholders.
5. Risk Management: Proactively identify, assess, and mitigate risks to minimize the likelihood and impact of security incidents.

5. Security Framework and Controls

PrimeHealth employs a multi-layered approach to information security, with the following core principles:

- a. Access Control
 - Role-Based Access Control (RBAC): Access to information and systems is granted based on defined roles and is reviewed quarterly.
 - Multi-Factor Authentication (MFA): Access to critical systems (e.g., patient data, diagnostics) requires MFA.
 - Principle of Least Privilege: Users are granted only the minimum access necessary to perform their roles.
- b. Data Protection and Encryption

- Encryption in Transit and at Rest: All sensitive information, including patient health records and financial data, must be encrypted using AES-256 or equivalent during both transmission and storage.
 - Data Masking and Anonymization: Where appropriate, sensitive data (e.g., patient identifiers) will be masked or anonymized to reduce exposure to unauthorized access.
- c. Physical Security
- Controlled access to physical locations (e.g., server rooms, diagnostic labs) will be enforced via keycard systems, surveillance, and access logs.
 - Workstations handling sensitive information must comply with strict security protocols, including screen locking and data encryption.

6. Incident Management

PrimeHealth maintains an Incident Response Plan (IRP) to address any security incidents, breaches, or system failures. This includes:

- Incident Identification: Employees must immediately report any suspicious activity or suspected breaches.
- Containment and Recovery: The CSO will lead the containment of incidents and initiate recovery procedures.
- Root Cause Analysis: Post-incident investigations will be conducted to identify the cause and ensure appropriate corrective actions are taken.

Risk Management and Risk Appetite

- Quarterly Risk Assessments: The ISC will conduct risk assessments every quarter, focusing on critical systems, such as patient data management, diagnostics, and financial records.
- Risk Appetite: PrimeHealth has a defined risk appetite, accepting low levels of risk for patient care-related systems and diagnostics. Higher risks are mitigated with controls like encryption, access management, and incident response protocols.

Business Continuity and Disaster Recovery

- PrimeHealth will maintain a Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP) to ensure the continuity of critical operations (e.g., patient care, diagnostics) in the event of security incidents or natural disasters.
- Annual Testing: The BCP and DRP will be tested annually, with results reviewed by the ISC for necessary updates.

7. Legal and Regulatory Compliance

PrimeHealth Clinic & Diagnostics is committed to complying with relevant legal, regulatory, and contractual obligations, including but not limited to:

- Privacy Act 1988 (Australia): Protecting patient privacy and ensuring data protection in healthcare services.
- General Data Protection Regulation (GDPR): Ensuring proper handling of personal data, especially for international operations.
- Health Insurance Portability and Accountability Act (HIPAA): Protecting patient health information in telehealth and clinical systems.
- Australian Protective Security Policy Framework (PSPF): Adhering to national security guidelines and procedures.

8. Training and Awareness

PrimeHealth will provide comprehensive and ongoing training to ensure that all employees understand their responsibilities regarding information security. Training will include:

- General Security Awareness: For all employees, focusing on basic security principles, password management, and recognizing phishing or social engineering attempts.
- Role-Specific Training: Specialized training for employees handling sensitive data (e.g., patient health records, financial systems) and for those in high-risk areas (e.g., IT, diagnostics).
- Incident Reporting Procedures: Employees will be trained on how to report potential security incidents promptly and correctly.

9. Incident Reporting and Breach Management

In the event of a security incident:

1. Immediate Reporting: Employees must report any suspected breaches or incidents to the CSO within 24 hours.
2. Response Activation: The CSO will activate the Incident Response Plan (IRP), involving containment, mitigation, and recovery actions.
3. Stakeholder Communication: Relevant stakeholders, including patients, regulatory bodies, and legal teams, will be notified promptly if the breach impacts patient data or regulatory compliance.
4. Post-Incident Review: After containment, the ISC will conduct a full review of the incident, including a root cause analysis, and implement any corrective actions.

10. Continuous Improvement and Review

PrimeHealth Clinic & Diagnostics is committed to the ongoing improvement of its ISMS. This will be achieved through:

- Annual Internal Audits: The ISMS will be audited annually, with results reviewed by the ISC and any non-conformities addressed promptly.

- Management Reviews: Senior management will review ISMS performance quarterly, ensuring that it remains aligned with the organization's goals and emerging threats.
- Policy Updates: This Information Security Policy will be reviewed annually, or when significant organizational changes occur, to ensure continued relevance and compliance.

11. Supporting reference and evidence documents

- ISO 27001:2022 Information Security Management System
- [ISO27K1_8.2] Business Processes, Information Assets & Risks Register
- Business Continuity and Disaster Recovery Plan: 05. [ISO27K1_A17.1.1] Business Continuity & Disaster Recovery Plan
- This policy has been supported with the following ISO 27001 clauses:
- List of Standards, Frameworks and Legislation
- ISMS Scope
- [ISO27K1_6.1.2] -Information Security Risk Assessment
- [ISO27K1_6.1.3]- Information Security Risk Treatment Plan
 - Information Security Risk Treatment_Statement of Applicability (SoA)
 - Information security Objectives and plans
 - ISMS Internal audits
 - ISMS Management reviews
 - Nonconformities and corrective actions
 - Continual Improvement
- [ISO 27001 Information Security Policy Ultimate Guide \[+ template\] \(hightable.io\)](#)
- [Information Security Policy – University of Newcastle](#)